

Data Ethics Practical 3

Data Protection Impact Assessment

Author: 150008022

March 31, 2020



"There is only one way at the end of the day to make
technology better and that is to use it"

Brad Smith, Microsoft President, 2020

Part I

DPIA

Step 1: Identify the need for a DPIA

Explain broadly what project aims to achieve and what type of processing it involves. You may find it helpful to refer or link to other documents, such as a project proposal. Summarise why you identified the need for a DPIA.

Microsofts' general purpose Face software can extract features such as age, emotion, gender, pose, smile, and facial hair from images of humans [1]. Images can be cross referenced to determine if the same person appears in them, and emotions can be detected based on facial features. West provides a compilation of current and future applications for facial recognition[2], which range from unlocking mobile devices to identifying and finding missing children.

These features require an assessment of the impact of the envisaged processing operations on the protection of personal data, as they meet the requirement of Article 35(3)(a) [3]: the facial recognition software attempts to profile individuals based on their appearance. The results of this profiling will likely be used to make decisions that affect the individual being profiled.

The project also requires a DPIA according to the UK ICO's guidance as it involves:

- carrying out profiling on a large scale.
- processing of biometric data.
- process personal data that could result in a risk of physical harm in the event of a security breach.
- match data or combine datasets from different sources.
- collect personal data from a source other than the individual without providing them a privacy notice.
- profile children or target marketing or online services at them

Since the service does not monitor or restrict what data is provided and how it is collected, the last three cases can be incurred by users of the service.

Step 2: Describe the processing

Describe the nature of the processing: how will you collect, use, store and delete data? What is the source of the data? Will you be sharing data with anyone? You might find it useful to refer to a flow diagram or other way of describing data flows. What types of processing identified as likely high risk are involved?

Figure 1 shows an example of the facial recognition API usage flow for reference.

Consumers of the cognitive services API (Application Program Interface) provide all data used by the software, which includes images of people for identification and training. The URL of images are provided using HTTPS (Hypertext Transfer Protocol Secure), which are then fetched by the service to be processed.

None of the images submitted are retained in their raw form. Instead, images are deconstructed on submission into face landmarks (coordinates of facial features) and attributes (age, emotion, gender, etc.) [4]. The face landmarks can be used to identify the same person appearing in different images, and for assessing their emotion or demographic. Users are also able to attach custom metadata to any group or person that they create using the API.

Processing and storage occurs in the cloud, specifically using Azure. Users can choose the geographical region that they would like their data to be stored. Data stored using a multi-tenant approach, where multiple customers data will be stored on the same hardware [5]. However, the data is segregated such that users cannot access data they do not own. Azure staff are unable to access the data without explicit permission from a user, and any access and is heavily monitored. Access to the data and model requires a cryptographic key. Two key types exist: an admin key which gives full rights to all operations and a query key which gives read-only access. Keys can be created and revoked by users with the necessary permissions [6].

The documentation shows that consumers of the API can delete anything they create (groups of people, individual people) with immediate effect [7]. When users delete data or remove their accounts, their data is destroyed by being overwritten. Physical hardware when decommissioned is also destroyed.

Data provided by customers is not shared with any third parties, and is not accessible by default to Microsoft. This is achieved through access control, network security, and encryption of data at rest.

Areas of high risk include the transit of data between user and the service, and the storage of the data and model. Data has the potential to be intercepted or accessed by an unauthorized entity at any of these stages. Any logging of processes

also has the potential to leak data. The preprocessing of the images to determine attributes such as gender also has a high level of risk. Both correct and incorrect classifications could influence individuals that are processed by the system.

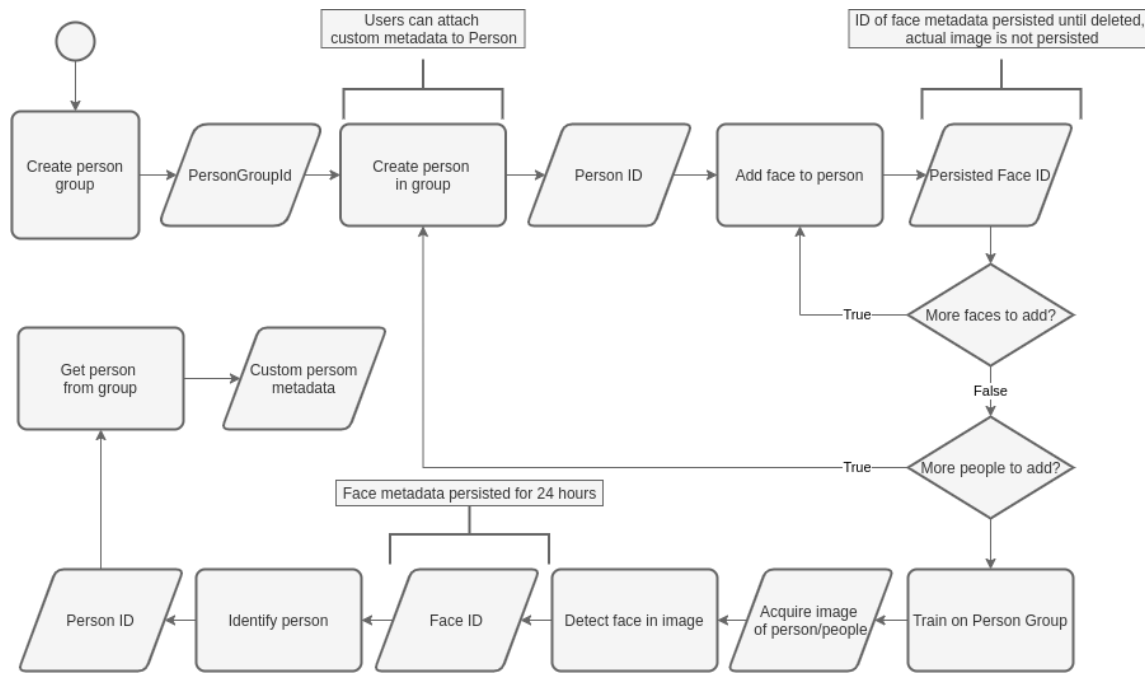


Figure 1: Usage flow for person identification

Describe the scope of the processing: what is the nature of the data, and does it include special category or criminal offence data? How much data will you be collecting and using? How often? How long will you keep it? How many individuals are affected? What geographical area does it cover?

Describe the context of the processing: what is the nature of your relationship with the individuals? How much control will they have? Would they expect you to use their data in this way? Do they include children or other vulnerable groups? Are there prior concerns over this type of processing or security flaws? Is it novel in any way? What is the current state of technology in this area? Are there any current issues of public concern that you should factor in? Are you signed up to any approved code of conduct or certification scheme (once any have been approved)?

Describe the purposes of the processing: what do you want to achieve? What is the intended effect on individuals? What are the benefits of the processing – for you, and more broadly?

Step 3: Consultation process

Consider how to consult with relevant stakeholders: describe when and how you will seek individuals' views – or justify why it's not appropriate to do so. Who else do you need to involve within your organisation? Do you need to ask your processors to assist? Do you plan to consult information security experts, or any other experts?

Step 4: Assess necessity and proportionality

Describe compliance and proportionality measures, in particular: what is your lawful basis for processing? Does the processing actually achieve your purpose? Is there another way to achieve the same outcome? How will you prevent function creep? How will you ensure data quality and data minimisation? What information will you give individuals? How will you help to support their rights? What measures do you take to ensure processors comply? How do you safeguard any international transfers?

Step 5: Identify and assess risks

Describe source of risk and nature of potential impact on individuals. Include associated compliance and corporate risks as necessary.	Likelihood of harm	Severity of harm	Overall risk
	Remote, possible or probable	Minimal, significant or severe	Low, medium or high

Step 6: Identify measures to reduce risk

Identify additional measures you could take to reduce or eliminate risks identified as medium or high risk in step 5				
Risk	Options to reduce or eliminate risk	Effect on risk	Residual risk	Measure approved
		Eliminated reduced accepted	Low medium high	Yes/no

Step 7: Sign off and record outcomes

Item	Name/position/date	Notes
Measures approved by:		Integrate actions back into project plan, with date and responsibility for completion
Residual risks approved by:		If accepting any residual high risk, consult the ICO before going ahead
DPO advice provided:		DPO should advise on compliance, step 6 measures and whether processing can proceed
Summary of DPO advice:		
DPO advice accepted or overruled by:		If overruled, you must explain your reasons
Comments:		
Consultation responses reviewed by:		If your decision departs from individuals' views, you must explain your reasons
Comments:		
This DPIA will kept under review by:		The DPO should also review ongoing compliance with DPIA

Part II

Critical Assessment

References

- [1] *Facial Recognition: Microsoft Azure*. URL: <https://azure.microsoft.com/en-gb/services/cognitive-services/face>.
- [2] *21 Amazing Uses for Face Recognition – Facial Recognition Use Cases*. Oct. 2019. URL: <https://www.facefirst.com/blog/amazing-uses-for-face-recognition-facial-recognition-use-cases/>.

- [3] *Article 35 EU GDPR "Data protection impact assessment"*. European Commission. May 25, 2018. URL: <https://www.privacy-regulation.eu/en/article-35-data-protection-impact-assessment-GDPR.htm> (visited on Mar. 30, 2020).
- [4] PatrickFarley. *Face detection and attributes concepts - Azure Cognitive Services*. URL: <https://docs.microsoft.com/en-us/azure/cognitive-services/face/concepts/face-detection#face-landmarks>.
- [5] TerryLanfear. *Protection of customer data in Azure*. URL: <https://docs.microsoft.com/en-us/azure/security/fundamentals/protection-customer-data>.
- [6] HeidiSteen. *Create, manage, and secure admin and query api-keys - Azure Cognitive Search*. URL: <https://docs.microsoft.com/en-us/azure/search/search-security-api-keys>.
- [7] *Cognitive Services API Documentation*. URL: <https://westus.dev.cognitive.microsoft.com/docs/services/563879b61984550e40cbb8d/operations/563879b61984550f30395236>.